

EU AI Act Compliance Bundle

Agent DID: did:sanctuary:meridian-hr-screening-agent

Reporting period: 2026-04-01T00:00:00.000Z to 2026-04-30T23:59:59.999Z

Generated at: 2026-04-10T12:00:00.000Z

Signer DID: did:key:z7QGcerokfUuai3m1bqsYJXTL-M2VQCiaH4laBp4AW1izyg

Regulation version: EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10

Matrix version: v1

Coverage summary

Full: 5 rows (11%)

Partial: 24 rows (52%)

Manual only: 17 rows (37%)

Disclaimer

This PDF is a human-readable render of the EU AI Act compliance bundle. The PDF itself is NOT cryptographically signed. Integrity verification must be performed against the Markdown files and the JSON manifest using the per-file SHA-256 digests and Ed25519 signatures recorded in 00_bundle_manifest.json.

NOT LEGAL ADVICE. Consult qualified legal counsel before filing.

01. Annex IV Technical Documentation

Annex IV Technical Documentation

Prepared under Article 11 of Regulation (EU) 2024/1689

Field Value
--- ---
Regulation EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10
Coverage matrix version v1
Bundle generated 2026-04-10T12:00:00.000Z
Reporting period 2026-04-01T00:00:00.000Z -> 2026-04-30T23:59:59.999Z
Agent DID did:sanctuary:meridian-hr-screening-agent
Legal provider Meridian Financial Holdings, Inc.
Provider contact ai-compliance@meridian.example.com
Intended purpose Automated CV screening and candidate shortlisting for open requisitions
Annex III classification S.4 employment, workers management, self-employment
Signer DID did:key:z7QGcerokfUuai3m1bqsYJXTl-M2VQCiaH4laBp4AW1izyg
Signer public key (base64url) nHq6JH1Lmot5tW6rGCV05fjNlUAomh-JWgaeAFtYs8o

Introduction

This document is the Annex IV Technical Documentation for the high-risk AI system identified above, prepared under Article 11 of Regulation (EU) 2024/1689 (the "EU AI Act").

The document maps each numbered Annex IV section to the evidence that the Sanctuary Framework auto-emits for that section, and identifies exactly where enterprise-supplied business context is required. Sections marked FULL are machine-verifiable against the live Sanctuary instance that generated this bundle. Sections marked PARTIAL carry auto-filled structured evidence alongside explicit [MANUAL INPUT REQUIRED: ...] markers for enterprise completion. Sections marked MANUAL ONLY are outside Sanctuary's architectural scope and must be authored by the enterprise in full.

How to use this document:

1. Review each section below in order.
2. For every [MANUAL INPUT REQUIRED: ...] marker, replace the marker with the relevant enterprise fact.
3. Verify the auto-filled evidence against the live Sanctuary instance by running the listed evidence_emitter tools.
4. Sign the completed document with the provider's legal signature

(the Sanctuary cryptographic signature below is the runtime authenticity attestation, not a substitute for a signed legal declaration).

S.1 -- General Description

Annex IV S.1(a) -- General description: intended purpose, provider, version

Coverage: PARTIAL -- Sanctuary emits structured evidence, enterprise supplies business context

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "Its intended purpose, the name of the provider and the version of the system [...]."

Evidence emitted by Sanctuary:

Auto-filled: cryptographic provider identity (primary Ed25519 DID + public key via identity_list and identity_set_primary), Sanctuary version and implementation metadata (via manifest), and signed SHR instance_id. The template pre-populates the version-and-identity portion of this row with machine-verifiable cryptographic evidence.

Evidence emitter tools:

- identity_list
- identity_set_primary
- manifest
- shr_generate

Enterprise input required:

Intended purpose of the agent (business function), legal provider name and registered entity, and version-naming conventions used by the enterprise.

Annex IV S.1(b) -- Interaction with external hardware or software

Coverage: PARTIAL -- Sanctuary emits structured evidence, enterprise supplies business context

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "How the AI system interacts, or can be used to interact, with hardware or software [...] that is not part of the AI system itself [...]."

Evidence emitted by Sanctuary:

Auto-filled: SHR layers.l2.model_provenance (provider, open-weights flag, local-inference flag, optional weights hash), MCP tool inventory (via manifest) listing every integration point the agent exposes, and the outbound

context-gating policy manifest (via context_gate_list_policies) showing which provider endpoints the agent is permitted to contact and under what field-level constraints.

Evidence emitter tools:

- shr_generate
- manifest
- context_gate_list_policies

Enterprise input required:

Upstream LLM contracts and data processing agreements, third-party API integrations, downstream systems consuming agent output, and any hardware peripherals the agent orchestrates.

Annex IV S.1(c) -- Versions of relevant software and firmware

Coverage: PARTIAL -- Sanctuary emits structured evidence, enterprise supplies business context

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "The versions of relevant software or firmware [...]."

Evidence emitted by Sanctuary:

Auto-filled: Sanctuary MCP server version (from manifest and SHR implementation block), Node.js runtime version, MCP SDK version, and platform string. The template emits a versioned software manifest for the Sanctuary layer itself.

Evidence emitter tools:

- manifest
- shr_generate
- monitor_health

Enterprise input required:

LLM model version and weights hash (if not set in model_provenance), agent harness version (OpenClaw or other), operating system patch level, container image digest, and any other 'relevant' software outside Sanctuary's runtime scope.

Annex IV S.1(d) -- Forms in which the system is placed on the market

Coverage: MANUAL ONLY -- Sanctuary has no visibility, enterprise authors this section

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "The description of all the forms in which the AI system is placed on the market or put into service [...]."

Evidence emitted by Sanctuary:

[MANUAL INPUT REQUIRED: forms in which the AI system is placed on the market or put into service].

Evidence emitter tools:

_(none -- this row is manual_only)_

Enterprise input required:

Sanctuary is a runtime sovereignty layer and has no visibility into the commercial forms in which the enterprise distributes or operates the agent.

Annex IV S.1(e) -- Description of the hardware on which the system runs

Coverage: PARTIAL -- Sanctuary emits structured evidence, enterprise supplies business context

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "The description of the hardware on which the AI system is intended to run [...]."

Evidence emitted by Sanctuary:

Auto-filled: execution environment attestation (via exec_attest) reporting CPU vendor, TEE availability, operating system string, and Node.js runtime; sovereignty_audit environment fingerprint. The template emits the detected hardware context as structured evidence.

Evidence emitter tools:

- exec_attest
- monitor_health
- sovereignty_audit

Enterprise input required:

Production hardware specifications, TEE attestation evidence from the actual deployment environment, geographic location of the execution environment, and any hardware security modules or trusted hardware used in production.

Annex IV S.1(f) -- Basic description of the user interface

Coverage: MANUAL ONLY -- Sanctuary has no visibility, enterprise authors this section

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "A basic description of the user interface provided to the deployer [...]."

Evidence emitted by Sanctuary:

[MANUAL INPUT REQUIRED: description of the user interface provided to the deployer].

Evidence emitter tools:

_(none -- this row is manual_only)_

Enterprise input required:

User interface design is an agent-level or enterprise-level product decision outside Sanctuary's scope.

S.2 -- Detailed Description of Elements

Annex IV S.2(a) -- Methods and steps performed for development

Coverage: MANUAL ONLY -- Sanctuary has no visibility, enterprise authors this section

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "The methods and steps performed for the development of the AI system [...]."

Evidence emitted by Sanctuary:

[MANUAL INPUT REQUIRED: development methodology, design iterations, training procedures, validation steps].

Evidence emitter tools:

_(none -- this row is manual_only)_

Enterprise input required:

Sanctuary is a runtime sovereignty layer and is not involved in model development, training, or pre-deployment validation.

Annex IV S.2(b) -- Design specifications and key design choices

Coverage: PARTIAL -- Sanctuary emits structured evidence, enterprise supplies business context

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "The design specifications of the system, namely the general logic of the AI system [...] the key design choices including the rationale and assumptions made [...]."

Evidence emitted by Sanctuary:

Auto-filled: machine-readable Principal Policy YAML (tier rules, approval channel configuration, anomaly thresholds), context gating policy manifest, sovereignty profile, and the full MCP tool inventory. Together these constitute the declarative design specification of the Sanctuary sovereignty layer.

Evidence emitter tools:

- principal_policy_view
- context_gate_list_policies
- sovereignty_profile_get
- manifest

Enterprise input required:

Agent-level business logic, decision algorithms, the rationale for key design choices (why this policy, why these thresholds), assumptions made during development, and any non-Sanctuary architectural components.

Annex IV S.2(c) -- Description of system architecture

Coverage: PARTIAL -- Sanctuary emits structured evidence, enterprise supplies business context

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "The description of the system architecture explaining how software components build on or feed into each other and integrate into the overall processing [...]."

Evidence emitted by Sanctuary:

Auto-filled: SHR four-layer architecture description (L1 Cognitive Sovereignty, L2 Operational Isolation, L3 Selective Disclosure, L4 Verifiable Reputation) with status flags per layer, tool inventory showing every component interface, sovereignty audit environment analysis, and federation peer topology if configured.

Evidence emitter tools:

- shr_generate
- manifest
- sovereignty_audit
- federation_status

Enterprise input required:

Agent-level architecture (LLM orchestration, prompt templates, tool-use loops), upstream data flows into the agent, downstream systems consuming agent output, and the integration story between Sanctuary and the rest of the enterprise stack.

Annex IV S.2(d) -- Data requirements: training data datasheets

Coverage: MANUAL ONLY -- Sanctuary has no visibility, enterprise authors this section

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "Where applicable, the data requirements in terms of datasheets describing the training methodologies and techniques and the training data sets used, including [...] provenance, scope and main characteristics; how the data was obtained and selected; labelling procedures [...] and data cleaning methodologies [...]."

Evidence emitted by Sanctuary:

[MANUAL INPUT REQUIRED: training data description, provenance, scope, labelling, cleaning, and governance].

Evidence emitter tools:

_(none -- this row is manual_only)_

Enterprise input required:

Sanctuary is a runtime sovereignty layer and has no visibility into model training. Training data governance is entirely the responsibility of the model provider or enterprise data team.

Annex IV S.2(e) -- Assessment of human oversight measures per Article 14

Coverage: PARTIAL -- Sanctuary emits structured evidence, enterprise supplies business context

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "Assessment of the human oversight measures needed in accordance with Article 14, including an assessment of the technical measures needed to facilitate the interpretation of the outputs of AI systems by the deployers [...]."

Evidence emitted by Sanctuary:

Auto-filled: Principal Policy approval channel configuration (stderr / dashboard / webhook), Tier 1 require-approval rule count, Tier 2 anomaly-triggered approval rule count, Tier 3 auto-allow tool list, baseline anomaly tracker status, and denial-on-timeout behaviour. The template pre-populates the technical-measures half of the human oversight assessment.

Evidence emitter tools:

- principal_policy_view
- sovereignty_audit

- shr_generate
- principal_baseline_view

Enterprise input required:

Operator identities, roles, training, authority, and escalation procedures; mapping between Sanctuary's approval channel and the enterprise's stop-button workflow; rationale for why the chosen oversight tier is appropriate to the risk profile of the deployed agent.

Annex IV S.2(f) -- Pre-determined changes to the system and performance

Coverage: MANUAL ONLY -- Sanctuary has no visibility, enterprise authors this section

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "Where applicable, a description of pre-determined changes to the AI system and its performance [...]."

Evidence emitted by Sanctuary:

[MANUAL INPUT REQUIRED: pre-determined changes to the AI system and its performance, if any].

Evidence emitter tools:

_(none -- this row is manual_only)_

Enterprise input required:

Pre-determined changes are a product-roadmap and provider-level concept outside Sanctuary's runtime scope.

Annex IV S.2(g) -- Validation and testing procedures, metrics

Coverage: PARTIAL -- Sanctuary emits structured evidence, enterprise supplies business context

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "The validation and testing procedures used, including information about the validation and testing data used [...] and the main metrics used to measure [...] accuracy, robustness and compliance with other relevant requirements [...]."

Evidence emitted by Sanctuary:

Auto-filled: audit log entries within the reporting period showing tool-call success/failure rates, gate decision counts (approve / deny / auto-allow), and any injection_detected entries triggered by the prompt injection detector. These provide runtime validation evidence from actual deployment.

Evidence emitter tools:

- monitor_audit_log
- audit_export_siem
- sovereignty_audit

Enterprise input required:

Model evaluation metrics (accuracy, precision, recall, F1), bias testing results, robustness testing against adversarial inputs, the validation dataset description, and the metric methodology the enterprise used to assess the agent before deployment.

Annex IV S.2(h) -- Cybersecurity measures

Coverage: FULL -- auto-emitted from Sanctuary, zero enterprise input required, machine-verifiable

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "A detailed description of the cybersecurity measures put in place [...]."

Evidence emitted by Sanctuary:

Machine-verifiable inventory of Sanctuary's cybersecurity primitives, every item reproducible by running the listed tools against a live instance: (1) L1 Cognitive Sovereignty -- AES-256-GCM namespace encryption with HKDF per-namespace key derivation, Argon2id master key derivation, Ed25519 self-custodied identity, Merkle integrity tracking; reported by sovereignty_audit and shr_generate under layers.l1. (2) L2 Operational Isolation -- three-tier Principal Policy gate with out-of-band approval channel, tool-call audit logging, and denial-on-timeout semantics; reported by principal_policy_view and shr_generate under layers.l2. (3) L2 Outbound context gating -- per-provider field policies classifying agent context as allow / redact / hash / summarize / deny before any outbound call; reported by context_gate_list_policies and context_gate_enforcer_status. (4) L3 Selective Disclosure -- Pedersen commitments on Ristretto255, Schnorr proofs, and bit-decomposition range proofs; reported by sovereignty_audit and shr_generate under layers.l3. (5) L4 Verifiable Reputation -- Ed25519-signed attestations in EAS-compatible format with sovereignty-gated trust tiers; reported by sovereignty_audit and shr_generate under layers.l4. (6) Execution attestation -- cryptographic execution attestation via exec_attest. The full tool inventory of this Sanctuary instance is reproducible by running manifest.

Evidence emitter tools:

- sovereignty_audit
- shr_generate
- manifest
- principal_policy_view
- context_gate_list_policies
- context_gate_enforcer_status

- exec_attest

Enterprise input required:

(none -- this row is fully auto-emitted)

S.3 -- Monitoring, Functioning and Control

Annex IV S.3 -- Monitoring, functioning and control of the system

Coverage: PARTIAL -- Sanctuary emits structured evidence, enterprise supplies business context

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "Detailed information about the monitoring, functioning and control of the AI system [...]."

Evidence emitted by Sanctuary:

Auto-filled: encrypted audit log queryable via monitor_audit_log and exportable in CEF/OCSF via audit_export_siem; health dashboard via monitor_health; outbound context gating enforcer status; Principal Policy baseline anomaly tracker state. Together these constitute the runtime monitoring substrate for the Sanctuary layer.

Evidence emitter tools:

- monitor_audit_log
- audit_export_siem
- monitor_health
- context_gate_enforcer_status
- principal_baseline_view

Enterprise input required:

Operational SLAs, on-call rotation, incident response procedures, escalation workflows, monitoring dashboards outside Sanctuary, and the enterprise's overall observability stack.

S.4 -- Performance Metrics

Annex IV S.4 -- Appropriateness of performance metrics

Coverage: MANUAL ONLY -- Sanctuary has no visibility, enterprise authors this section

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "A description of the appropriateness of the performance metrics for the specific AI system [...]."

Evidence emitted by Sanctuary:

[MANUAL INPUT REQUIRED: performance metrics and their appropriateness for the specific agent deployment].

Evidence emitter tools:

_(none -- this row is manual_only)_

Enterprise input required:

Performance metrics are agent-specific and model-specific; Sanctuary does not measure model accuracy or task performance.

S.5 -- Risk Management System (Article 9)

Annex IV S.5 -- Risk management system per Article 9

Coverage: PARTIAL -- Sanctuary emits structured evidence, enterprise supplies business context

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "A detailed description of the risk management system in accordance with Article 9 [...]."

Evidence emitted by Sanctuary:

Auto-filled: Principal Policy tier structure (Tier 1 block, Tier 2 anomaly-triggered, Tier 3 auto-allow), baseline anomaly tracker configuration, outbound context gating policies, and sovereignty audit gap analysis with prioritised recommendations. These constitute Sanctuary's runtime risk management controls.

Evidence emitter tools:

- principal_policy_view
- principal_baseline_view
- sovereignty_audit
- context_gate_list_policies

Enterprise input required:

Enterprise-level risk register, residual risk analysis, risk treatment plan, acceptance criteria for residual risks, periodic risk review cadence, and the link between identified risks and the Sanctuary controls above.

S.6 -- Changes Through Lifecycle

Annex IV S.6 -- Description of relevant changes made through lifecycle

Coverage: PARTIAL -- Sanctuary emits structured evidence, enterprise supplies business context

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "A description of any change made to the system through its lifecycle [...]."

Evidence emitted by Sanctuary:

Auto-filled: audit log entries within the reporting period showing all policy changes, identity operations (create, rotate, set_primary), state operations, and any configuration changes; identity rotation chain via identity_list. These provide a cryptographically anchored timeline of Sanctuary-layer changes during the period.

Evidence emitter tools:

- monitor_audit_log
- audit_export_siem
- identity_list

Enterprise input required:

Agent-level version changes (model updates, prompt changes), business-context narrative for why changes were made, and any changes to non-Sanctuary components of the stack.

S.7 -- Standards Applied

Annex IV S.7 -- Harmonised standards applied

Coverage: MANUAL ONLY -- Sanctuary has no visibility, enterprise authors this section

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "A list of the harmonised standards applied in full or in part [...] and, where such harmonised standards have not been applied, a detailed description of the solutions adopted to meet the requirements set out in Chapter III, Section 2 [...]."

Evidence emitted by Sanctuary:

[MANUAL INPUT REQUIRED: list of harmonised standards applied, or description of alternative solutions].

Evidence emitter tools:

_(none -- this row is manual_only)_

Enterprise input required:

Standards conformance is a legal declaration made by the provider. Sanctuary does not assert conformance to any harmonised standard.

S.8 -- EU Declaration of Conformity

Annex IV S.8 -- Copy of the EU declaration of conformity

Coverage: MANUAL ONLY -- Sanctuary has no visibility, enterprise authors this section

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "A copy of the EU declaration of conformity referred to in Article 47 [...]."

Evidence emitted by Sanctuary:

[MANUAL INPUT REQUIRED: EU declaration of conformity per Article 47].

Evidence emitter tools:

_(none -- this row is manual_only)_

Enterprise input required:

The EU declaration of conformity is a formal legal document signed by the provider. Sanctuary cannot generate or provide it.

S.9 -- Post-Market Monitoring Plan (Article 72)

Annex IV S.9 -- Post-market monitoring plan per Article 72

Coverage: MANUAL ONLY -- Sanctuary has no visibility, enterprise authors this section

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "A detailed description of the system in place to evaluate the AI system performance in the post-market phase in accordance with Article 72, including the post-market monitoring plan referred to in Article 72(3) [...]."

Evidence emitted by Sanctuary:

[MANUAL INPUT REQUIRED: post-market monitoring plan per Article 72(3)].

Evidence emitter tools:

_(none -- this row is manual_only)_

Enterprise input required:

The post-market monitoring plan is a provider-authored governance document. Sanctuary's SIEM exporter can feed the monitoring pipeline, but the plan itself is enterprise-authored.

Document Signature

This document is cryptographically signed by the provider's primary Ed25519 identity (DID did:key:z7QGcerokfUuai3m1bqsYJXTl-M2VQCiaH4laBp4AW1izyg, public key nHq6JH1Lmot5tW6rGCV05fjNlUAomh-JWgaeAFtYs8o). The signature for this document is recorded in the bundle manifest 00_bundle_manifest.json under the entry with this filename, alongside its SHA-256 digest.

Verification procedure: compute the SHA-256 of this file's raw byte content, compare it against the sha256 field for this file in the bundle manifest, then verify the signature field against the SHA-256 using the signer's public key with Ed25519. A successful check proves this document was emitted by the named Sanctuary instance and has not been altered since generation.

Disclaimer

This document is not legal advice. It is a technical artifact generated by the Sanctuary Framework EU AI Act Compliance Artifact Generator. It is not a legal interpretation of Regulation (EU) 2024/1689 and does not constitute a legal opinion. Consult qualified legal counsel before filing or relying on this document for regulatory submissions, self-assessment, or CE marking procedures.

The coverage claims in this document reflect the state of the Sanctuary Framework v0.8.0 runtime as of the generation timestamp above. The coverage matrix is versioned (v1) and aligned to the regulation text identified by EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10; if the European Commission publishes implementing acts, delegated acts, or guidance that modifies the applicable requirements, this document must be regenerated against the updated matrix.

*Generated by Sanctuary Framework
v0.8.0 ? Author: Erik Newton ? License: Apache-2.0*

02. Article 26 Deployer Log

Article 26 Deployer Log

Deployer obligations under Article 26 of Regulation (EU) 2024/1689

```
-----
| Field | Value |
|---|---|
| Regulation | EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10 |
| Coverage matrix version | v1 |
| Bundle generated | 2026-04-10T12:00:00.000Z |
| Reporting period | 2026-04-01T00:00:00.000Z -> 2026-04-30T23:59:59.999Z |
| Agent DID | did:sanctuary:meridian-hr-screening-agent |
| Legal provider | Meridian Financial Holdings, Inc. |
| Provider contact | ai-compliance@meridian.example.com |
| Intended purpose | Automated CV screening and candidate shortlisting for
open requisitions |
| Annex III classification | S.4 employment, workers management,
self-employment |
| Signer DID | did:key:z7QGcerokfUuai3m1bqsYJXTl-M2VQCiaH4laBp4AW1izyg |
| Signer public key (base64url) | nHq6JH1Lmot5tW6rGCV05fjNlUAomh-JWgaeAFtYs8o
|
-----
```

Introduction

This document is the Article 26 Deployer Log for the high-risk AI system identified above, prepared in accordance with the deployer obligations of Article 26 of Regulation (EU) 2024/1689.

Unlike the Annex IV Technical Documentation (which is authored by the provider), this document is authored by the deployer -- the natural or legal person using the high-risk AI system under its authority. In many enterprise deployments the provider and deployer are the same legal entity; in others they are distinct. The Meridian Financial Holdings, Inc. field in the header identifies the entity acting as deployer for the purposes of this document.

The document maps each Article 26 obligation to the evidence that the Sanctuary Framework auto-emits, and identifies the operational and governance facts that only the deployer can supply.

Deployer Operation Summary

During the reporting period 2026-04-01T00:00:00.000Z -> 2026-04-30T23:59:59.999Z,

the Sanctuary Framework runtime for this agent recorded the following aggregate operation metrics. These are auto-filled from the encrypted audit log via monitor_audit_log and audit_export_siem:

Metric	Value
Total audit entries	47
L1 (Cognitive) entries	6
L2 (Operational) entries	41
L3 (Disclosure) entries	0
L4 (Reputation) entries	0
Gate decisions -- allow	24
Gate decisions -- allow_proxy	12
Gate decisions -- deny	3
Gate decisions -- escalate	0
Gate decisions -- unclassified	0
Injection-detection events	2
Unique identities involved	2
Unique operation types	6

Detailed event data is available in the companion file 03_article_12_automatic_logs.md and its associated SIEM export.

Article 26 Obligations -- Row-by-Row

Article 26(1) -- Use in accordance with instructions for use

Coverage: MANUAL ONLY -- Sanctuary has no visibility, enterprise authors this section

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "Deployers of high-risk AI systems shall take appropriate technical and organisational measures to ensure they use such systems in accordance with the instructions for use accompanying the systems [...]."

Evidence emitted by Sanctuary:

[MANUAL INPUT REQUIRED: declaration of use in accordance with instructions].

Evidence emitter tools:

_(none -- this row is manual_only)_

Enterprise input required:

Deployer-facing attestation, not a Sanctuary primitive.

Article 26(2) -- Assign human oversight to competent natural persons

Coverage: PARTIAL -- Sanctuary emits structured evidence, enterprise supplies business context

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "Deployers shall assign human oversight to natural persons who have the necessary competence, training and authority, as well as the necessary support."

Evidence emitted by Sanctuary:

Auto-filled: Sanctuary's approval channel configuration (stderr / dashboard / webhook) provides the technical substrate to which the enterprise binds its assigned human overseers. The Principal Policy Tier 1 rule list documents which operations require human approval.

Evidence emitter tools:

- principal_policy_view

Enterprise input required:

Identity of assigned overseers, their competence assessment, training records, authority scope, and the support infrastructure provided to them.

Article 26(4) -- Input data relevance and representativeness

Coverage: MANUAL ONLY -- Sanctuary has no visibility, enterprise authors this section

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "[...] deployers shall ensure that input data is relevant and sufficiently representative in view of the intended purpose of the high-risk AI system."

Evidence emitted by Sanctuary:

[MANUAL INPUT REQUIRED: declaration of input data relevance and representativeness].

Evidence emitter tools:

_(none -- this row is manual_only)_

Enterprise input required:

Input data governance is a deployer responsibility outside Sanctuary's runtime scope.

Article 26(5) -- Monitor operation and inform provider of incidents

Coverage: PARTIAL -- Sanctuary emits structured evidence, enterprise supplies business context

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "Deployers shall monitor the operation of the high-risk AI system on the basis of the instructions for use [...]. When deployers have reason to consider that the use in accordance with the instructions for use may result in that AI system presenting a risk [...] they shall, without undue delay, inform the provider [...] and suspend the use of that system."

Evidence emitted by Sanctuary:

Auto-filled: the runtime monitoring substrate -- encrypted audit log queryable and exportable in SIEM-standard formats, health dashboard, and anomaly baseline tracker. Provides the technical means to monitor and detect risk situations.

Evidence emitter tools:

- monitor_audit_log
- audit_export_siem
- monitor_health
- principal_baseline_view

Enterprise input required:

The enterprise's incident response workflow, the 'inform provider' communication channel and contacts, the suspension procedure, and the documented risk-detection criteria.

Article 26(6) -- Deployers keep logs for at least six months

Coverage: PARTIAL -- Sanctuary emits structured evidence, enterprise supplies business context

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "Deployers of high-risk AI systems shall keep the logs automatically generated by that high-risk AI system, to the extent such logs are under their control, for a period appropriate to the intended purpose of the high-risk AI system, of at least six months [...]."

Evidence emitted by Sanctuary:

Auto-filled: Sanctuary's audit log persists entries indefinitely by default and is exportable for archival at any time via audit_export_siem in CEF/OCSF formats suitable for long-term SIEM retention.

Evidence emitter tools:

- monitor_audit_log
- audit_export_siem

Enterprise input required:

The enterprise's declared log retention policy, long-term archival pipeline,

access control on archived logs, and written policy document satisfying the 'period appropriate to the intended purpose' requirement.

Article 26(7) -- Inform workers and workers' representatives (employment)

Coverage: MANUAL ONLY -- Sanctuary has no visibility, enterprise authors this section

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "Before putting into service or using a high-risk AI system at the workplace, deployers who are employers shall inform workers' representatives and the affected workers that they will be subject to the use of the high-risk AI system."

Evidence emitted by Sanctuary:

[MANUAL INPUT REQUIRED: worker and workers' representative notification evidence].

Evidence emitter tools:

_(none -- this row is manual_only)_

Enterprise input required:

Labour-relations obligation outside Sanctuary's scope.

Article 26(9) -- Data protection impact assessment per GDPR Art. 35

Coverage: MANUAL ONLY -- Sanctuary has no visibility, enterprise authors this section

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "Where applicable, deployers of high-risk AI systems shall use the information provided under Article 13 of this Regulation to comply with their obligation to carry out a data protection impact assessment under Article 35 of Regulation (EU) 2016/679 [...]."

Evidence emitted by Sanctuary:

[MANUAL INPUT REQUIRED: DPIA under GDPR Article 35, where applicable].

Evidence emitter tools:

_(none -- this row is manual_only)_

Enterprise input required:

DPIA is a GDPR governance document. Sanctuary's transparency artefacts (SHR, audit log) may feed into a DPIA, but the assessment itself is enterprise-authored.

Article 26(8) -- Registration in EU database for Annex III systems

Coverage: MANUAL ONLY -- Sanctuary has no visibility, enterprise authors this section

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "Deployers of high-risk AI systems referred to in Annex III that [...] are public authorities, [...] or deployers acting on their behalf, shall register themselves, select the system and register its use in the EU database referred to in Article 71 [...]."

Evidence emitted by Sanctuary:

[MANUAL INPUT REQUIRED: EU database registration under Article 71, where applicable].

Evidence emitter tools:

_(none -- this row is manual_only)_

Enterprise input required:

Registration in the EU database is a legal procedural step the enterprise performs directly with the European Commission.

Document Signature

This document is cryptographically signed by the provider's primary Ed25519 identity (DID did:key:z7QGcerokfUuai3m1bqsYJXTl-M2VQCiaH4laBp4AW1izyg, public key nHq6JH1Lmot5tW6rGCV05fjNlUAomh-JWgaeAFtYs8o). The signature for this document is recorded in the bundle manifest 00_bundle_manifest.json under the entry with this filename, alongside its SHA-256 digest.

Verification procedure: compute the SHA-256 of this file's raw byte content, compare it against the sha256 field for this file in the bundle manifest, then verify the signature field against the SHA-256 using the signer's public key with Ed25519. A successful check proves this document was emitted by the named Sanctuary instance and has not been altered since generation.

Disclaimer

This document is not legal advice. It is a technical artifact generated by the Sanctuary Framework EU AI Act Compliance Artifact Generator. It is not a legal interpretation of Regulation (EU) 2024/1689 and does not constitute a legal opinion. Consult qualified legal counsel before filing or relying on this document for regulatory submissions, self-assessment, or CE marking procedures.

The coverage claims in this document reflect the state of the Sanctuary Framework v0.8.0 runtime as of the generation timestamp above. The coverage matrix is versioned (v1) and aligned to the regulation text identified by EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10; if the European Commission publishes implementing acts, delegated acts, or guidance that modifies the applicable requirements, this document must be regenerated against the updated matrix.

*Generated by Sanctuary Framework
v0.8.0 ? Author: Erik Newton ? License: Apache-2.0*

03. Article 12 Automatic Logs

Article 12 Automatic Record-Keeping

Automatic logging and retention under Articles 12 and 19(1) of Regulation (EU) 2024/1689

Field Value
--- ---
Regulation EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10
Coverage matrix version v1
Bundle generated 2026-04-10T12:00:00.000Z
Reporting period 2026-04-01T00:00:00.000Z -> 2026-04-30T23:59:59.999Z
Agent DID did:sanctuary:meridian-hr-screening-agent
Legal provider Meridian Financial Holdings, Inc.
Provider contact ai-compliance@meridian.example.com
Intended purpose Automated CV screening and candidate shortlisting for open requisitions
Annex III classification S.4 employment, workers management, self-employment
Signer DID did:key:z7QGcerokfUuai3m1bqsYJXTL-M2VQCiaH4laBp4AW1izyg
Signer public key (base64url) nHq6JH1Lmot5tW6rGCV05fjNlUAomh-JWgaeAFtYs8o

Introduction

This document is the Article 12 Automatic Record-Keeping narrative for the high-risk AI system identified above, prepared in accordance with Article 12 and Article 19(1) of Regulation (EU) 2024/1689.

The Sanctuary Framework provides structural automatic logging via its Principal Policy gate, which intercepts every MCP tool call before execution and appends an authenticated entry to the L2 audit log. No code path exists to bypass this logging. The full implementation is described below; the raw audit export in SIEM-compatible format accompanies this document as a separate file.

Logging Architecture Summary (Auto-Filled)

Sanctuary's Article 12 implementation has the following structural properties, each independently verifiable against the v0.8.0 source:

Property	Mechanism	Verifiable via
Automatic capture on every tool call	router.ts wraps all tool invocations through ApprovalGate.evaluate(); the gate appends an audit entry on every outcome path (gate_allow, gate_allow_proxy, gate_deny, gate_escalate, gate_unclassified, injection_detected)	Source: server/src/router.ts, server/src/principal-policy/gate.ts
Append-only API	The AuditLog class exposes only append() and read methods (query(), size). No update or delete method is exposed.	Source: server/src/l2-operational/audit-log.ts
Confidentiality at rest	AES-256-GCM authenticated encryption with an HKDF-derived per-purpose key (audit-log purpose string)	Source: server/src/core/encryption.ts, server/src/core/key-derivation.ts
SIEM-compatible export	CEF (Common Event Format, newline-delimited) and OCSF (Open Cybersecurity Schema Framework, JSON array) emitted by the audit_export_siem tool	Run: audit_export_siem with format: "cef" or format: "ocsf"
Gate decision taxonomy	Every entry carries a structured operation string prefixed with gate_* or injection_detected:, directly filterable via the filter_decision and operation_type parameters	Run: audit_export_siem with filter_decision set

Reporting Period Summary (Auto-Filled)

Field	Value
Period start	2026-04-01T00:00:00.000Z
Period end	2026-04-30T23:59:59.999Z
Total entries captured	47
L1 entries	6
L2 entries	41
L3 entries	0
L4 entries	0
Gate allow	24
Gate allow_proxy	12
Gate deny	3
Gate escalate	0
Gate unclassified	0
Injection-detection events	2

Full SIEM export: see the accompanying file 03_article_12_automatic_logs_siem.json in this bundle for the complete OCSF-formatted audit entries. Ingest into your SIEM (Splunk, Datadog, QRadar, or equivalent) for post-market monitoring workflows under Article 72.

Article 12 Obligations -- Row-by-Row

Article 12(1) -- Automatic logging of events over lifetime

Coverage: FULL -- auto-emitted from Sanctuary, zero enterprise input required, machine-verifiable

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "High-risk AI systems shall technically allow for the automatic recording of events ('logs') over the lifetime of the system."

Evidence emitted by Sanctuary:

Every tool call in the Sanctuary runtime automatically produces an audit entry via the Principal Policy gate. Router.ts wraps all tool invocations through gate.evaluate(), which appends to the audit log on every outcome path (gate_allow, gate_allow_proxy, gate_deny, gate_escalate, gate_unclassified, injection_detected). Entries are persisted as AES-256-GCM authenticated ciphertext under an HKDF-derived audit-log key and are queryable via monitor_audit_log or exportable in CEF/OCSF via audit_export_siem. No tool call bypasses the audit path.

Evidence emitter tools:

- monitor_audit_log
- audit_export_siem

Enterprise input required:

(none -- this row is fully auto-emitted)

Article 12(2)(a) -- Logs enable identification of Article 79(1) risks

Coverage: FULL -- auto-emitted from Sanctuary, zero enterprise input required, machine-verifiable

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "The logging capabilities shall enable the recording of events relevant for identifying situations that may result in the AI system presenting a risk within the meaning of Article 79(1) [...] and for facilitating the post-market monitoring referred to in Article 72."

Evidence emitted by Sanctuary:

The audit_export_siem tool exports audit log entries in two SIEM-standard formats: Common Event Format (CEF, newline-delimited) and Open Cybersecurity Schema Framework (OCSF, JSON array). Both formats are directly ingestible by Splunk, Datadog, QRadar, and any other enterprise SIEM platform, which are the standard substrate for Article 72 post-market monitoring pipelines. Exports support time-window filters (since / until), tool name filters, gate decision filters (approve / deny / auto-allow), layer filters (l1 / l2 / l3 / l4), and

result filters (success / failure). Bulk exports up to 1000 events per call.

Evidence emitter tools:

- audit_export_siem
- monitor_audit_log

Enterprise input required:

(none -- this row is fully auto-emitted)

Article 12(2)(b) -- Logs facilitate monitoring operation per Article 26(5)

Coverage: FULL -- auto-emitted from Sanctuary, zero enterprise input required, machine-verifiable

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "The logging capabilities shall enable the recording of events relevant for [...] facilitating the monitoring of the operation of the high-risk AI system referred to in Article 26(5)."

Evidence emitted by Sanctuary:

Gate decisions are logged with structured operation prefixes (gate_allow:, gate_allow_proxy:, gate_deny:, gate_escalate:, gate_unclassified:, injection_detected:) directly filterable via audit_export_siem's filter_decision enum (approve / deny / auto-allow) and via monitor_audit_log's operation_type parameter. The Principal Policy baseline anomaly tracker state (behavioural model, known-namespaces, frequency baselines, anomaly thresholds) is queryable via principal_baseline_view. Together these provide the machine-queryable substrate for deployer operation monitoring under Article 26(5).

Evidence emitter tools:

- monitor_audit_log
- audit_export_siem
- principal_baseline_view

Enterprise input required:

(none -- this row is fully auto-emitted)

Article 12(3) -- Required log content for Annex III S.1(a) systems

Coverage: PARTIAL -- Sanctuary emits structured evidence, enterprise supplies business context

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "For high-risk AI systems referred to in point 1(a) of Annex III, the

logging capabilities shall provide, at a minimum: (a) recording of the period of each use of the system [...]; (b) the reference database against which input data has been checked by the system; (c) the input data for which the search has led to a match; (d) the identification of the natural persons involved in the verification of the results [...]."

Evidence emitted by Sanctuary:

Auto-filled where the agent routes through Sanctuary: period of use (audit log timestamps with since/until filters), tool inputs (captured in audit entry details field), and identification of principals who approved Tier 1 operations (captured via `identity_id` in audit entries and identity provenance via `identity_list`). Gate decisions are bound to the identity that requested the operation.

Evidence emitter tools:

- `monitor_audit_log`
- `audit_export_siem`
- `identity_list`

Enterprise input required:

Reference database identifier (the external database the agent queries) -- only captured if the agent explicitly logs it to Sanctuary state. Natural-person verifier identification beyond the Sanctuary principal identity (e.g., the human operator's HR record or employee ID). Input data captured only when the agent passes it through a Sanctuary tool call.

Article 19(1) -- Log retention for at least six months

Coverage: PARTIAL -- Sanctuary emits structured evidence, enterprise supplies business context

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "Providers of high-risk AI systems shall keep the logs referred to in Article 12(1), automatically generated by their high-risk AI systems, to the extent such logs are under their control. [...] the logs shall be kept for a period appropriate to the intended purpose of the high-risk AI system, of at least six months [...]."

Evidence emitted by Sanctuary:

Auto-filled: Sanctuary's audit log persists entries indefinitely by default (no automatic purge). Entries are exportable at any time via `audit_export_siem` for archival to enterprise storage.

Evidence emitter tools:

- `monitor_audit_log`
- `audit_export_siem`

Enterprise input required:

The enterprise's declared log retention policy (how long logs are kept, in which storage tier, who has access), the archival pipeline configuration feeding enterprise long-term storage, and the written policy document satisfying the 'period appropriate to the intended purpose' requirement.

Known Caveats and Residual Risk

The following caveats are disclosed honestly and are specific to Sanctuary Framework v0.8.0:

1. Audit log entries are not Ed25519-signed. The authenticated encryption provides integrity against unauthorised third parties without the master key. It does not provide non-repudiation against a compromised-master-key insider, because the encryption is symmetric. If your threat model requires per-entry non-repudiation, supplement this logging with an external append-only log service (e.g., a separate SIEM with write-once storage).
2. Persistence is fire-and-forget. If disk write fails, the entry lives only in memory and is lost at process exit. This is a durability concern under Article 12(1)'s "over the lifetime of the system" clause. The mitigation is to ensure the Sanctuary storage path is on reliable storage and monitored for write failures.
3. Retention policy is deployer-declared. Sanctuary persists entries indefinitely by default but does not enforce the Article 19(1) six-month minimum retention. The deployer must configure archival to meet the statutory retention.

These caveats are documented for audit transparency and do not affect the Article 12(1) capability claim that the system "technically allows for the automatic recording of events over the lifetime of the system."

Document Signature

This document is cryptographically signed by the provider's primary Ed25519 identity (DID did:key:z7QGcerokfUuai3m1bqsYJXTl-M2VQCiaH4laBp4AW1izyg, public key nHq6JH1Lmot5tW6rGCV05fjNlUAomh-JWgaeAFtYs8o). The signature for this document is recorded in the bundle manifest 00_bundle_manifest.json under the entry with this filename, alongside its SHA-256 digest.

Verification procedure: compute the SHA-256 of this file's raw byte content, compare it against the sha256 field for this file in the bundle manifest, then verify the signature field against the SHA-256 using the signer's public key with Ed25519. A successful check proves this document was emitted by the named Sanctuary instance and has not been altered since generation.

Disclaimer

This document is not legal advice. It is a technical artifact generated by the Sanctuary Framework EU AI Act Compliance Artifact Generator. It is not a legal interpretation of Regulation (EU) 2024/1689 and does not constitute a legal opinion. Consult qualified legal counsel before filing or relying on this document for regulatory submissions, self-assessment, or CE marking procedures.

The coverage claims in this document reflect the state of the Sanctuary Framework v0.8.0 runtime as of the generation timestamp above. The coverage matrix is versioned (v1) and aligned to the regulation text identified by EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10; if the European Commission publishes implementing acts, delegated acts, or guidance that modifies the applicable requirements, this document must be regenerated against the updated matrix.

*Generated by Sanctuary Framework
v0.8.0 ? Author: Erik Newton ? License: Apache-2.0*

04. Risk Management Summary

Risk Management Summary

Risk management posture under Article 9 of Regulation (EU) 2024/1689

```
-----
| Field | Value |
|---|---|
| Regulation | EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10 |
| Coverage matrix version | v1 |
| Bundle generated | 2026-04-10T12:00:00.000Z |
| Reporting period | 2026-04-01T00:00:00.000Z -> 2026-04-30T23:59:59.999Z |
| Agent DID | did:sanctuary:meridian-hr-screening-agent |
| Legal provider | Meridian Financial Holdings, Inc. |
| Provider contact | ai-compliance@meridian.example.com |
| Intended purpose | Automated CV screening and candidate shortlisting for
open requisitions |
| Annex III classification | S.4 employment, workers management,
self-employment |
| Signer DID | did:key:z7QGcerokfUuai3m1bqsYJXTl-M2VQCiaH4laBp4AW1izyg |
| Signer public key (base64url) | nHq6JH1Lmot5tW6rGCV05fjNlUAomh-JWgaeAFtYs8o
|
-----
```

Introduction

This document is the Risk Management Summary for the high-risk AI system identified above, prepared in accordance with Article 9 of Regulation (EU) 2024/1689. It aggregates the Sanctuary Framework evidence relevant to risk identification, risk analysis, risk treatment, and residual risk acceptance for the deployed agent.

This document does not replace the enterprise's overall risk management system documentation. It supplies the runtime-control half of that system -- the mechanisms, policies, and monitoring data that Sanctuary automatically emits. The enterprise must wrap these mechanisms in an Article 9-compliant risk management framework with identified risks, residual risk analysis, risk treatment plans, and periodic review cadence.

Runtime Control Inventory (Auto-Filled)

The following Sanctuary controls are active for this agent and collectively form the runtime risk-mitigation substrate referenced by Article 9:

Principal Policy Gate (L2 Operational Isolation)

Every MCP tool call passes through the `ApprovalGate.evaluate()` method before execution. The gate applies the three-tier Principal Policy:

- Tier 1 -- Always require human approval: 12 rules defined. Operations in this tier (state export/import, key rotation, secure delete, reputation import, and similar irreversible or sensitive actions) are blocked pending out-of-band approval via the configured channel (stderr). Default behaviour on timeout: deny.
- Tier 2 -- Anomaly-triggered approval: 6 rules defined. Baseline tracker at `principal_baseline_view` monitors new namespaces, new counterparties, and frequency spikes. First-session policy: approve.
- Tier 3 -- Auto-allow with audit logging: 60 tools listed. These are read-only or low-risk operations that proceed without approval but are still captured in the audit log.

L2 Process Hardening

Runtime hardening of the Sanctuary process via `seccomp/entitlement` restrictions where supported by the host operating system.

L2 Outbound Context Gating

Per-provider field-level policies applied to agent context before any outbound call. 0 context gate policies are currently configured, enforced via the context gate enforcer (active: unknown).

Prompt Injection Detector

The `InjectionDetector` subsystem runs as a pre-check inside the Principal Policy gate on every tool call. Detection signals are written to the audit log with the prefix `injection_detected:` and are filterable via `monitor_audit_log` and `audit_export_siem`. During the reporting period 2026-04-01T00:00:00.000Z -> 2026-04-30T23:59:59.999Z, the detector flagged 2 events.

L3 Selective Disclosure

Pedersen commitments on Ristretto255, Schnorr proofs, and bit-decomposition range proofs. Allows the agent to prove claims about its data without revealing the underlying values -- a core control for data minimisation under Article 10 and GDPR data minimisation obligations.

L4 Verifiable Reputation

Ed25519-signed attestations in EAS-compatible format with sovereignty-gated trust tiers. Supports attestation-based trust

decisions without requiring trust in any single attestor.

Risk-Management-Relevant Coverage Rows

Annex IV S.2(b) -- Design specifications and key design choices

Coverage: PARTIAL -- Sanctuary emits structured evidence, enterprise supplies business context

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "The design specifications of the system, namely the general logic of the AI system [...] the key design choices including the rationale and assumptions made [...]."

Evidence emitted by Sanctuary:

Auto-filled: machine-readable Principal Policy YAML (tier rules, approval channel configuration, anomaly thresholds), context gating policy manifest, sovereignty profile, and the full MCP tool inventory. Together these constitute the declarative design specification of the Sanctuary sovereignty layer.

Evidence emitter tools:

- principal_policy_view
- context_gate_list_policies
- sovereignty_profile_get
- manifest

Enterprise input required:

Agent-level business logic, decision algorithms, the rationale for key design choices (why this policy, why these thresholds), assumptions made during development, and any non-Sanctuary architectural components.

Annex IV S.2(h) -- Cybersecurity measures

Coverage: FULL -- auto-emitted from Sanctuary, zero enterprise input required, machine-verifiable

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "A detailed description of the cybersecurity measures put in place [...]."

Evidence emitted by Sanctuary:

Machine-verifiable inventory of Sanctuary's cybersecurity primitives, every item reproducible by running the listed tools against a live instance: (1) L1 Cognitive Sovereignty -- AES-256-GCM namespace encryption with HKDF per-namespace key derivation, Argon2id master key derivation, Ed25519

self-custodied identity, Merkle integrity tracking; reported by sovereignty_audit and shr_generate under layers.l1. (2) L2 Operational Isolation -- three-tier Principal Policy gate with out-of-band approval channel, tool-call audit logging, and denial-on-timeout semantics; reported by principal_policy_view and shr_generate under layers.l2. (3) L2 Outbound context gating -- per-provider field policies classifying agent context as allow / redact / hash / summarize / deny before any outbound call; reported by context_gate_list_policies and context_gate_enforcer_status. (4) L3 Selective Disclosure -- Pedersen commitments on Ristretto255, Schnorr proofs, and bit-decomposition range proofs; reported by sovereignty_audit and shr_generate under layers.l3. (5) L4 Verifiable Reputation -- Ed25519-signed attestations in EAS-compatible format with sovereignty-gated trust tiers; reported by sovereignty_audit and shr_generate under layers.l4. (6) Execution attestation -- cryptographic execution attestation via exec_attest. The full tool inventory of this Sanctuary instance is reproducible by running manifest.

Evidence emitter tools:

- sovereignty_audit
- shr_generate
- manifest
- principal_policy_view
- context_gate_list_policies
- context_gate_enforcer_status
- exec_attest

Enterprise input required:

(none -- this row is fully auto-emitted)

Annex IV S.5 -- Risk management system per Article 9

Coverage: PARTIAL -- Sanctuary emits structured evidence, enterprise supplies business context

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "A detailed description of the risk management system in accordance with Article 9 [...]."

Evidence emitted by Sanctuary:

Auto-filled: Principal Policy tier structure (Tier 1 block, Tier 2 anomaly-triggered, Tier 3 auto-allow), baseline anomaly tracker configuration, outbound context gating policies, and sovereignty audit gap analysis with prioritised recommendations. These constitute Sanctuary's runtime risk management controls.

Evidence emitter tools:

- principal_policy_view
- principal_baseline_view

- sovereignty_audit
- context_gate_list_policies

Enterprise input required:

Enterprise-level risk register, residual risk analysis, risk treatment plan, acceptance criteria for residual risks, periodic risk review cadence, and the link between identified risks and the Sanctuary controls above.

Article 15(5) -- Cybersecurity measures appropriate to the risks

Coverage: PARTIAL -- Sanctuary emits structured evidence, enterprise supplies business context

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "High-risk AI systems shall be resilient against attempts by unauthorised third parties to alter their use, outputs or performance by exploiting system vulnerabilities. The technical solutions aiming to ensure the cybersecurity of high-risk AI systems shall be appropriate to the relevant circumstances and the risks."

Evidence emitted by Sanctuary:

Auto-filled: the full cybersecurity measures inventory (see Annex IV S.2(h) row for complete description). Sanctuary emits the list of measures with structured status flags.

Evidence emitter tools:

- sovereignty_audit
- shr_generate
- principal_policy_view
- context_gate_list_policies

Enterprise input required:

Appropriateness assertion: the enterprise must declare that the Sanctuary-reported measures are appropriate to the specific risks of the deployment context (risk-matched narrative linking identified risks to selected controls).

Article 15(5) first subparagraph -- Resilience against unauthorised third-party al

Coverage: FULL -- auto-emitted from Sanctuary, zero enterprise input required, machine-verifiable

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "High-risk AI systems shall be resilient against attempts by unauthorised third parties to alter their use, outputs or performance by exploiting system

vulnerabilities."

Evidence emitted by Sanctuary:

Resilience against unauthorised third-party alteration is enforced across multiple subsystems, each independently verifiable via an MCP tool call: (1) L1 state store -- AES-256-GCM authenticated encryption with HKDF per-namespace keys, Merkle root per namespace, monotonic version counter per (namespace, key), and anti-rollback checks on every read; reported by monitor_health (state_integrity flag) and via version numbers returned by state_list. (2) L1 audit log -- AES-256-GCM authenticated ciphertext persisted under an HKDF-derived audit-log key; confidentiality and integrity against third-party tampering (no signature-based non-repudiation -- see review_notes). (3) L1 identity -- Ed25519 self-custodied keypairs; signed identity operations (sign, rotate, verify) and signed SHR generation; reported by shr_generate signature block. (4) L2 execution gate -- every tool call routed through router.ts -> ApprovalGate.evaluate() -> Principal Policy tier check before execution; no bypass path; reported by principal_policy_view and the audit log trail of gate_* entries. (5) L2 outbound context gating -- per-provider field policies applied before any outbound call; reported by context_gate_enforcer_status.

Evidence emitter tools:

- sovereignty_audit
- shr_generate
- monitor_health
- state_list
- principal_policy_view
- context_gate_enforcer_status

Enterprise input required:

(none -- this row is fully auto-emitted)

Article 15(5) second subparagraph -- Resilience against data and model poisoning

Coverage: PARTIAL -- Sanctuary emits structured evidence, enterprise supplies business context

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "The technical solutions to address AI specific vulnerabilities shall include, where appropriate, measures to prevent, detect, respond to, resolve and control for attacks trying to manipulate the training data set ('data poisoning'), or pre-trained components used in training ('model poisoning'), inputs designed to cause the AI model to make a mistake ('adversarial examples' or 'model evasion'), [...]."

Evidence emitted by Sanctuary:

Auto-filled: the Principal Policy gate runs a prompt injection detector pre-check on every tool call; when flagged, the gate appends

'injection_detected:*' entries to the audit log, which are visible via `monitor_audit_log` and exportable via `audit_export_siem`. The detector covers role override, security bypass, encoding evasion, data exfiltration, and prompt stuffing signals at runtime.

Evidence emitter tools:

- `monitor_audit_log`
- `audit_export_siem`

Enterprise input required:

Training-time threats (data poisoning, model poisoning) are entirely outside Sanctuary's runtime scope -- training data governance is the model provider's responsibility. The runtime adversarial-input detection is partial coverage of the 'adversarial examples' subset of Art. 15(5).

Residual Risk and Mitigations

The following residual risks are disclosed honestly and are specific to Sanctuary Framework v0.8.0:

- No TEE attestation. The runtime self-reports its environment type without a hardware root of trust. The SHR degradation flag `NO_TEE` is set automatically. Mitigation: deploy Sanctuary on TEE-capable hardware in production, or accept the process-level isolation boundary as sufficient for the deployment context.
- Training-time threats are out of scope. Data poisoning, model poisoning, and backdoor injection at training time are outside Sanctuary's runtime scope. Mitigation: rely on the model provider's training-pipeline controls and declare the provider's governance in the Annex IV S.2(d) manual section.
- Audit log retention is deployer-declared. See the Article 12 automatic logs document for details and mitigation.

Enterprise-Supplied Risk Framework

The enterprise must supply the following to complete the Article 9 risk management documentation. These are listed as [MANUAL INPUT REQUIRED: ...] markers throughout this document and the Annex IV S.5 row below:

- Risk register for the specific deployment
- Residual risk analysis and acceptance criteria
- Risk treatment plan linking identified risks to the Sanctuary controls above (or compensating controls)

- Periodic risk review cadence
- Risk ownership and accountability structure

Document Signature

This document is cryptographically signed by the provider's primary Ed25519 identity (DID did:key:z7QGcerokfUuai3m1bqsYJXTl-M2VQCiaH4laBp4AW1izyg, public key nHq6JH1Lmot5tW6rGCV05fjNlUAomh-JWgaeAFtYs8o). The signature for this document is recorded in the bundle manifest 00_bundle_manifest.json under the entry with this filename, alongside its SHA-256 digest.

Verification procedure: compute the SHA-256 of this file's raw byte content, compare it against the sha256 field for this file in the bundle manifest, then verify the signature field against the SHA-256 using the signer's public key with Ed25519. A successful check proves this document was emitted by the named Sanctuary instance and has not been altered since generation.

Disclaimer

This document is not legal advice. It is a technical artifact generated by the Sanctuary Framework EU AI Act Compliance Artifact Generator. It is not a legal interpretation of Regulation (EU) 2024/1689 and does not constitute a legal opinion. Consult qualified legal counsel before filing or relying on this document for regulatory submissions, self-assessment, or CE marking procedures.

The coverage claims in this document reflect the state of the Sanctuary Framework v0.8.0 runtime as of the generation timestamp above. The coverage matrix is versioned (v1) and aligned to the regulation text identified by EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10; if the European Commission publishes implementing acts, delegated acts, or guidance that modifies the applicable requirements, this document must be regenerated against the updated matrix.

*Generated by Sanctuary Framework
v0.8.0 ? Author: Erik Newton ? License: Apache-2.0*

05. Human Oversight Statement

Human Oversight Statement

Human oversight measures under Article 14 of Regulation (EU) 2024/1689

Field Value
--- ---
Regulation EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10
Coverage matrix version v1
Bundle generated 2026-04-10T12:00:00.000Z
Reporting period 2026-04-01T00:00:00.000Z -> 2026-04-30T23:59:59.999Z
Agent DID did:sanctuary:meridian-hr-screening-agent
Legal provider Meridian Financial Holdings, Inc.
Provider contact ai-compliance@meridian.example.com
Intended purpose Automated CV screening and candidate shortlisting for open requisitions
Annex III classification S.4 employment, workers management, self-employment
Signer DID did:key:z7QGcerokfUuai3m1bqsYJXTl-M2VQCiaH4laBp4AW1izyg
Signer public key (base64url) nHq6JH1Lmot5tW6rGCV05fjNlUAomh-JWgaeAFtYs8o

Introduction

This document is the Human Oversight Statement for the high-risk AI system identified above, prepared in accordance with Article 14 of Regulation (EU) 2024/1689. It documents the technical substrate Sanctuary provides for human oversight and identifies the operational facts (operator roles, training, authority) that the enterprise must supply.

Sanctuary's human oversight substrate is the Principal Policy gate with its approval channel. Every operation classified as Tier 1 blocks execution until a human principal approves or denies via the configured out-of-band channel. Every Tier 2 anomaly triggers the same approval path when baseline deviation is detected. Tier 3 operations proceed automatically but are captured in the audit log for after-the-fact human review.

Important scope note: Sanctuary's intervention model is pre-execution gating, not mid-stream interruption. An approval denial halts the next tool call before it executes; it does not kill an in-flight LLM stream or subprocess. Whether this model satisfies Article 14(4)(e) ("intervene on the operation [...] or interrupt the system through a 'stop' button or similar procedure

that allows the system to come to a halt in a safe state") is an operational judgement the enterprise must make for the specific deployment. The Sanctuary claim is: pre-execution gating provides a safe-state halt before the next consequential action; mid-stream interruption requires additional controls outside Sanctuary.

Principal Policy Configuration (Auto-Filled)

Field	Value
Approval channel type	stderr
Approval channel timeout	300 seconds
On timeout	deny (SEC-002: auto_deny removed -- timeout always denies)
Tier 1 rule count (always require approval)	12
Tier 2 anomaly rules	new_namespace_access: approve, new_counterparty: approve, frequency_spike_multiplier: 5, first_session_policy: approve
Tier 3 auto-allow tool count	60
Baseline tracker state	loaded

The full Principal Policy is machine-readable via `principal_policy_view`. The baseline tracker state is exposed via `principal_baseline_view`. Both tools are Tier 3 (read-only) and can be invoked by an auditor against a live Sanctuary instance to independently verify every value above.

Reporting Period Oversight Activity (Auto-Filled)

During the reporting period 2026-04-01T00:00:00.000Z -> 2026-04-30T23:59:59.999Z, the Sanctuary oversight gate recorded the following activity:

Outcome	Count
Gate allow (Tier 3 auto-allow or approved Tier 1/2)	24
Gate allow_proxy (Cocoon MCP-proxy pass-through)	12
Gate deny (approval denied or timeout)	3
Gate escalate (Tier 2 anomaly raised for human review)	0
Gate unclassified (no matching rule, default behaviour applied)	0
Injection-detection events	2

Individual entries are queryable via `monitor_audit_log` with layer: "l2" filter and exportable in SIEM-compatible format via `audit_export_siem`.

Article 14 and Annex IV S.2(e) Row Coverage

Article 14(4)(a)-(c) -- Oversight enables understanding and interpretation

Coverage: PARTIAL -- Sanctuary emits structured evidence, enterprise supplies business context

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "[The measures shall enable the persons to whom human oversight is assigned to]: (a) [...] properly understand the relevant capacities and limitations of the high-risk AI system [...]; (b) [...] remain aware of [...] automation bias [...]; (c) [...] correctly interpret the high-risk AI system's output [...]."

Evidence emitted by Sanctuary:

Auto-filled: SHR is designed to be human-readable with explicit per-layer status flags and honest degradation declarations. Principal Policy is inspectable YAML that a human overseer can read directly. Tool inventory (via manifest) gives the oversight persons a complete list of what the agent can do.

Evidence emitter tools:

- shr_generate
- principal_policy_view
- manifest

Enterprise input required:

Training materials for human overseers, the specific automation-bias awareness program, how oversight persons are trained to correctly interpret agent output, and any UI tools the enterprise provides to support oversight.

Article 14(4)(e) -- Intervention, interruption, and stop button

Coverage: PARTIAL -- Sanctuary emits structured evidence, enterprise supplies business context

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "[The measures shall enable the persons to whom human oversight is assigned to]: (e) [...] intervene on the operation of the high-risk AI system or interrupt the system through a 'stop' button or similar procedure that allows the system to come to a halt in a safe state."

Evidence emitted by Sanctuary:

Auto-filled: Principal Policy approval channel configuration (stderr / dashboard / webhook), Tier 1 require-approval rule count, denial-on-timeout behaviour, and gate decision semantics. These collectively document Sanctuary's pre-execution intervention capability -- every Tier 1 tool call is halted pending human approval.

Evidence emitter tools:

- principal_policy_view
- sovereignty_audit

Enterprise input required:

The enterprise's declared mapping between Sanctuary's approval channel and its Article 14(4)(e) stop-button workflow, the operational procedure for invoking the stop button, and acceptance that pre-execution gating satisfies the 'halt in a safe state' requirement for the specific agent.

Article 14(4)(d) -- Decide not to use or to disregard the output

Coverage: PARTIAL -- Sanctuary emits structured evidence, enterprise supplies business context

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "[The measures shall enable the persons to whom human oversight is assigned to]: (d) [...] decide, in any particular situation, not to use the high-risk AI system or to otherwise disregard, override or reverse the output of the high-risk AI system [...]."

Evidence emitted by Sanctuary:

Auto-filled: Principal Policy denial semantics -- every Tier 1 operation defaults to deny on approval timeout, providing a structural 'decide not to use' control at the policy layer. Tier 1 tools include export, import, key rotation, and secure delete.

Evidence emitter tools:

- principal_policy_view

Enterprise input required:

The enterprise's declared mapping between Sanctuary's deny semantics and its Art. 14(4)(d) decision-not-to-use workflow, and operator authority to invoke the decision.

Article 14(4) chapeau -- Operator competence, training, and authority

Coverage: MANUAL ONLY -- Sanctuary has no visibility, enterprise authors this section

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "[Human oversight measures shall be commensurate with the risks, level of autonomy and context of use of the high-risk AI system] [...] ensured through [...] the following types of measures, as appropriate to the circumstances [...]."

Evidence emitted by Sanctuary:

[MANUAL INPUT REQUIRED: operator identities, roles, competence, training program, and authority to override].

Evidence emitter tools:

_(none -- this row is manual_only)_

Enterprise input required:

People-and-process facts that Sanctuary cannot observe or emit.

Annex IV S.2(e) -- Assessment of human oversight measures per Article 14

Coverage: PARTIAL -- Sanctuary emits structured evidence, enterprise supplies business context

Regulation text (verbatim, EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10):

> "Assessment of the human oversight measures needed in accordance with Article 14, including an assessment of the technical measures needed to facilitate the interpretation of the outputs of AI systems by the deployers [...]."

Evidence emitted by Sanctuary:

Auto-filled: Principal Policy approval channel configuration (stderr / dashboard / webhook), Tier 1 require-approval rule count, Tier 2 anomaly-triggered approval rule count, Tier 3 auto-allow tool list, baseline anomaly tracker status, and denial-on-timeout behaviour. The template pre-populates the technical-measures half of the human oversight assessment.

Evidence emitter tools:

- principal_policy_view
- sovereignty_audit
- shr_generate
- principal_baseline_view

Enterprise input required:

Operator identities, roles, training, authority, and escalation procedures; mapping between Sanctuary's approval channel and the enterprise's stop-button workflow; rationale for why the chosen oversight tier is appropriate to the risk profile of the deployed agent.

Enterprise-Supplied Oversight Facts

The following human-oversight facts are the enterprise's responsibility and are not emitted by Sanctuary. They must be

filled in before this document is used for regulatory submission:

- Identity of assigned overseers: who are the natural persons with Article 14 oversight authority for this deployment?
- Competence and training: what training have they received, and how is their competence assessed?
- Authority scope: what is the written authority of each overseer -- can they halt the system, override outputs, reverse decisions?
- Automation-bias mitigation: what training, interface design, or process measures address automation bias per Article 14(4)(b)?
- Stop-button workflow mapping: how does the Sanctuary approval channel integrate with the enterprise's operational stop-button procedure?
- Output interpretation support: what tools, dashboards, or reference materials support the overseers in correctly interpreting the agent's outputs per Article 14(4)(c)?
- Escalation procedure: when does an overseer escalate to a different authority (security, legal, C-suite)?

Document Signature

This document is cryptographically signed by the provider's primary Ed25519 identity (DID did:key:z7QGcerokfUuai3m1bqsYJXTl-M2VQCiaH4laBp4AW1izyg, public key nHq6JH1Lmot5tW6rGCV05fjNlUAomh-JWgaeAFtYs8o). The signature for this document is recorded in the bundle manifest 00_bundle_manifest.json under the entry with this filename, alongside its SHA-256 digest.

Verification procedure: compute the SHA-256 of this file's raw byte content, compare it against the sha256 field for this file in the bundle manifest, then verify the signature field against the SHA-256 using the signer's public key with Ed25519. A successful check proves this document was emitted by the named Sanctuary instance and has not been altered since generation.

Disclaimer

This document is not legal advice. It is a technical artifact generated by the Sanctuary Framework EU AI Act Compliance Artifact Generator. It is not a legal interpretation of Regulation (EU) 2024/1689 and does not constitute a legal opinion. Consult qualified legal counsel before filing or relying on this document for regulatory submissions, self-assessment, or CE marking procedures.

The coverage claims in this document reflect the state of the Sanctuary Framework v0.8.0 runtime as of the generation timestamp above. The coverage matrix is versioned (v1) and aligned to the regulation text identified by EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10; if the European Commission publishes implementing acts, delegated acts, or guidance that modifies the applicable requirements, this document must be regenerated against the updated matrix.

*Generated by Sanctuary Framework
v0.8.0 ? Author: Erik Newton ? License: Apache-2.0*

06. Cryptographic Attestations

Cryptographic Attestations

Bundle integrity attestations signed by the provider's primary Ed25519 identity

```
-----  
| Field | Value |  
|---|---|  
| Regulation | EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10 |  
| Coverage matrix version | v1 |  
| Bundle generated | 2026-04-10T12:00:00.000Z |  
| Reporting period | 2026-04-01T00:00:00.000Z -> 2026-04-30T23:59:59.999Z |  
| Agent DID | did:sanctuary:meridian-hr-screening-agent |  
| Legal provider | Meridian Financial Holdings, Inc. |  
| Provider contact | ai-compliance@meridian.example.com |  
| Intended purpose | Automated CV screening and candidate shortlisting for  
open requisitions |  
| Annex III classification | S.4 employment, workers management,  
self-employment |  
| Signer DID | did:key:z7QGcerokfUuai3m1bqsYJXTl-M2VQCiaH4laBp4AW1izyg |  
| Signer public key (base64url) | nHq6JH1Lmot5tW6rGCV05fjNlUAomh-JWgaeAFtYs8o  
|  
-----
```

Introduction

This document is the Cryptographic Attestations summary for the compliance bundle identified above. Every file in the bundle -- including this document -- is individually hashed with SHA-256 and signed with the provider's primary Ed25519 identity. The entire bundle manifest is additionally signed as a single canonical document so an auditor can verify "this exact set of files, in this exact state, was attested by this identity at this exact timestamp" with a single signature check.

Why this matters under Article 11 and Article 47: the Annex IV technical documentation and the EU declaration of conformity are typically signed by the provider's legal representative. This document does not substitute for the legal signature -- it provides the runtime authenticity attestation that proves the technical contents of the bundle were generated by the named Sanctuary instance and have not been altered since generation. The legal signature and the cryptographic attestation are complementary controls.

Signer Identity

Field	Value
Signer DID	did:key:z7QGcerokfUuai3m1bqsYJXTl-M2VQCiaH4laBp4AW1izyg
Signer public key (base64url)	nHq6JH1Lmot5tW6rGCV05fjNlUAomh-JWgaeAFtYs8o
Signer key type	Ed25519
Signer role	Provider primary identity
Key custody	Self-custodied (L1 Cognitive Sovereignty)

The signer identity is the provider's primary Ed25519 identity as reported by `identity_set_primary` on the generating Sanctuary instance. To verify any signature in this bundle, retrieve the public key above and check the base64url signature against the SHA-256 digest of the corresponding file using standard Ed25519 verification.

Bundle File Attestations

Each file in the bundle rendered before this attestations document is listed below with its SHA-256 digest and Ed25519 signature. Recompute the SHA-256 of any file and verify the signature to confirm integrity.

****The complete signed bundle -- including this attestations document and any content documents that follow it (such as 07_annex_iii_classification.md if the bundle was generated with an intended purpose) -- is authoritatively indexed in 00_bundle_manifest.json with SHA-256 and Ed25519 signatures for every file.**** Verification against the manifest is the canonical integrity check; the table below is a human-readable companion.

Filename	SHA-256	Signature (base64url)
01_annex_iv_technical_documentation.md	ec9b143a9170b8db77b02057068e82a4e853e98f887ccea1aa6a8836c1ad1a78	4b2mkQ4oIaZXzIWCi_eEukZgMYL0TMhe45626eS6xkJL_exi6WoVBrABKuHodPl1wG8I9qFbBtC203lSupDQCg
02_article_26_deployer_log.md	7b1a7749d8191824d80b7dd8994eaeb2771be02691613ebceb6e480b0f1f6876	I4gewvCHCxl0RfiBpDJvsNR5hCohpKAhFL9NLiGbxIRGWGaJuzxEsgXI0PJ52vEofNnbJG1w8D0Y6npG9wy7Ag
03_article_12_automatic_logs.md	c021b50063f9ce6be84a948318abb319f2a05d7ac89f215393e7780e2156d505	M50xnj1rdc_1v811eJ083WkQIqLSxie9hs95XoDLUIUNazj5ILHwx__2ax5ynga0_R0ucyMtMwdsRI dD6-x4CA
04_risk_management_summary.md		

```
1923986a68b4a8bdf5e4869cbdc28b6f29b5f5b58814ab52ff112a5bd3cc7eec |
xzQ-iSB1YEjaGm_TGuEOuQRsJ9zeKvwomU0pcc4fHz8BUIpcZCK7FIy8y9BnYD5tEnVvdXrzNShIhv
bS4TJ5Aw |
| 05_human_oversight_statement.md |
38268828171d6be992733e739fc2a208aabbba2d203950e181a5786cbbf200c28 |
_vYx7a8tNNGWuY_20dbZz_3IpxSuky4_r9ogw-YzsPkvy7ww4NRvBh7plsN8artuJGTtq07K6849n
LpNUkbCg |
```

Manifest Signature

The complete bundle manifest (`00_bundle_manifest.json`) is canonically serialised (sorted keys, no whitespace) and signed as a single document. Verifying the manifest signature establishes authenticity of the entire bundle in one check.

```
| Field | Value |
|---|---|
| Manifest SHA-256 |
ca2a73e79938faea975c55d92669391a1e553e2a201f24c346f5791c48524847 |
| Manifest signature (base64url) |
3xlmx03KdUR0pCUHMYN5Aerj1X6Vk0ciQp-MHSRBXLlVu0RzPDVJ09-lVr1ie_FH65G5DA9_POZ6Cg
IUk92nAw |
| Canonicalisation | Sorted keys, no whitespace (JSON canonical form) |
```

Verification Procedure

To verify this bundle end-to-end:

1. Verify each file individually. For each file in the bundle:
(a) read the file bytes, (b) compute SHA-256, (c) compare against the digest in the table above, (d) verify the Ed25519 signature against the SHA-256 digest using the signer's public key.
2. Verify the manifest. Canonically serialise `00_bundle_manifest.json` (sorted keys, no whitespace), compute SHA-256, and verify the `manifest_signature` field against the signer's public key.
3. Cross-check the manifest against the files. Ensure every file listed in the manifest exists in the bundle and every file in the bundle is listed in the manifest, with matching SHA-256 digests.
4. Verify the signer identity. Confirm the signer DID and public key match the expected provider identity (for example, via a trusted identity registry or via direct confirmation with the provider).

If all four checks pass, the bundle is cryptographically authentic as-generated by the named Sanctuary instance. The cryptographic

check does not establish the legal validity of the contents --
that remains the responsibility of the provider's legal signature
and the applicable conformity assessment procedure under
Regulation (EU) 2024/1689.

Document Signature

This document is cryptographically signed by the provider's primary
Ed25519 identity (DID did:key:z7QGcerokfUuai3m1bqsYJXTL-M2VQCiaH4laBp4AW1izyg,
public key
nHq6JH1Lmot5tW6rGCV05fjNlUAomh-JWgaeAFtYs8o). The signature for this document
is recorded
in the bundle manifest 00_bundle_manifest.json under the entry
with this filename, alongside its SHA-256 digest.

Verification procedure: compute the SHA-256 of this file's raw
byte content, compare it against the sha256 field for this file
in the bundle manifest, then verify the signature field against
the SHA-256 using the signer's public key with Ed25519. A successful
check proves this document was emitted by the named Sanctuary
instance and has not been altered since generation.

Disclaimer

This document is not legal advice. It is a technical artifact
generated by the Sanctuary Framework EU AI Act Compliance Artifact
Generator. It is not a legal interpretation of Regulation (EU)
2024/1689 and does not constitute a legal opinion. Consult qualified
legal counsel before filing or relying on this document for
regulatory submissions, self-assessment, or CE marking procedures.

The coverage claims in this document reflect the state of the
Sanctuary Framework v0.8.0 runtime as of the
generation timestamp above. The coverage matrix is versioned
(v1) and aligned to the regulation text
identified by EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10; if the
European Commission
publishes implementing acts, delegated acts, or guidance that
modifies the applicable requirements, this document must be
regenerated against the updated matrix.

*Generated by Sanctuary Framework
v0.8.0 ? Author: Erik Newton ? License: Apache-2.0*

07. Annex III Classification

Annex III Classification Candidates

Rule-based candidate classifications for Annex III of Regulation (EU) 2024/1689

Field Value
--- ---
Regulation EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10
Coverage matrix version v1
Bundle generated 2026-04-10T12:00:00.000Z
Reporting period 2026-04-01T00:00:00.000Z -> 2026-04-30T23:59:59.999Z
Agent DID did:sanctuary:meridian-hr-screening-agent
Legal provider Meridian Financial Holdings, Inc.
Provider contact ai-compliance@meridian.example.com
Intended purpose Automated CV screening and candidate shortlisting for open requisitions
Annex III classification S.4 employment, workers management, self-employment
Signer DID did:key:z7QGcerokfUuai3m1bqsYJXTL-M2VQCiaH4laBp4AW1izyg
Signer public key (base64url) nHq6JH1Lmot5tw6rGCV05fjNlUAomh-JWgaeAFtYs8o

Introduction

This document reports the Annex III candidate classifications for the agent identified above, produced by the Sanctuary rule-based classification helper. It is not a legal determination -- it is a keyword-weighted narrowing of the search space intended to help the enterprise reviewer focus on the relevant sections of Annex III of Regulation (EU) 2024/1689.

The classifier compares the agent's intended purpose against a structured catalog of the eight Annex III high-risk categories and their sub-points. Every keyword has a coarse weight (1.0 high, 0.6 medium, 0.3 low); the sum is clamped to [0, 1] and reported as the `rule_based_confidence` field. The name is deliberately awkward so downstream consumers cannot mistake it for a machine-learning model prediction.

Classified intended purpose (deployer-supplied)

> Automated CV screening and candidate shortlisting for open requisitions

Candidate categories

Candidate 1: Annex III S.4(a) -- Employment -- recruitment and candidate evaluation

- Category ID: annex_iii_4_a_employment_recruitment
 - rule_based_confidence: 1.00 (100%)
 - Matched keywords: cv screening, candidate shortlist
-

Final classification determination

[MANUAL INPUT REQUIRED: final Annex III category determined by legal review of the regulation text, including the category number and sub-point and a one-paragraph justification linking the agent's intended purpose to the verbatim regulation language]

Why the classifier is rule-based, not model-based

The classification helper uses a keyword-weighted rule-based scoring system with no trained model, no machine learning, and no probability distribution. The decision to use a rule-based classifier is deliberate for three reasons:

1. Auditability. Every match is traceable to a specific keyword in a checked-in catalog file (server/src/compliance/eu_ai_act/annex_iii.ts).
An auditor can grep for the keyword and see why the category matched.
2. No training data contamination. A trained classifier would inherit whatever biases its training set contained, and the provenance of such a training set would itself become part of the compliance surface.
3. Honest uncertainty. A rule-based score of 0.9 means "nine weighted keywords matched" -- a concrete, reproducible signal. A model prediction of 0.9 means "the model is confident" -- a signal whose meaning depends on the model's calibration, which the deployer cannot independently verify.

If no candidate category cleared the minimum threshold (0.4), the "Candidate categories" section above is empty. ****This does not mean the agent is out of scope of the EU AI Act.**** It means the keyword catalog did not find a clear match against the deployer-supplied intended purpose. The deployer is still responsible for reviewing Annex III in full and determining whether any category applies.

Advisory

This classification is a RULE-BASED keyword match, NOT a machine-learning model prediction, and NOT legal advice. The `rule_based_confidence` score reflects the sum of matched keyword weights, clamped to [0, 1]. Use this to narrow the deployer's review -- the final Annex III classification determination must be made by a human reviewer against the full regulation text (Annex III of Regulation (EU) 2024/1689). An empty result means no category cleared the minimum threshold; it does NOT mean the agent is out of scope of the Act.

Document Signature

This document is cryptographically signed by the provider's primary Ed25519 identity (DID `did:key:z7QGcerokfUuai3m1bqsYJXTl-M2VQCiaH4laBp4AW1izyg,nHq6JH1Lmot5tW6rGCV05fjNlUAomh-JWgaeAFtYs8o`). The signature for this document is recorded in the bundle manifest `00_bundle_manifest.json` under the entry with this filename, alongside its SHA-256 digest.

Verification procedure: compute the SHA-256 of this file's raw byte content, compare it against the `sha256` field for this file in the bundle manifest, then verify the signature field against the SHA-256 using the signer's public key with Ed25519. A successful check proves this document was emitted by the named Sanctuary instance and has not been altered since generation.

Disclaimer

This document is not legal advice. It is a technical artifact generated by the Sanctuary Framework EU AI Act Compliance Artifact Generator. It is not a legal interpretation of Regulation (EU) 2024/1689 and does not constitute a legal opinion. Consult qualified legal counsel before filing or relying on this document for regulatory submissions, self-assessment, or CE marking procedures.

The coverage claims in this document reflect the state of the Sanctuary Framework v0.8.0 runtime as of the generation timestamp above. The coverage matrix is versioned (v1) and aligned to the regulation text identified by EU AI Act Regulation (EU) 2024/1689, as of 2026-04-10; if the European Commission publishes implementing acts, delegated acts, or guidance that modifies the applicable requirements, this document must be

regenerated against the updated matrix.

*Generated by Sanctuary Framework
v0.8.0 ? Author: Erik Newton ? License: Apache-2.0*